

enSights

Security, Compliance & Identity Overview

For customer IT, Cyber Security and OT teams

Item	Detail
Document	Customer Security & Compliance Overview
Version / date	1.0 / September 2026
Classification	Customer Confidential – shared under NDA
Platform in scope	enSights cloud platform – central monitoring and asset management platform for optimizing renewable energy systems
Prepared by	enSights Product & Information Security
Security contact	Dekel Yaacov, CTO & Co-Founder – dekel@ensights.ai

How to read this document. Every statement below is traced to its source: an enSights information security policy (document ID and section number, e.g. **IS-P-001 Sec. 17.2**) and, where applicable, the ISO/IEC 27001:2022 surveillance audit report (Annex A control and report page, e.g. **Audit A.8.24, p.25**). Source documents are listed in Section 9 and are available on request.

1. Summary of requests and responses

The table below answers each item typically requested by customer IT and security teams during vendor onboarding and links to the section with full detail.

Request	enSights response	Status	Detail
Copies of / access to information security policies	Five core ISMS policies are available (Information Security, Secure Development, Cloud Computing, Business Continuity, Privacy). Shared under NDA.	Available	Sections 3 and 9
Standards compliance information	ISO/IEC 27001:2022 certified ISMS. SOC 2 examination in progress (final stages).	ISO: Certified SOC 2: In progress	Section 2
Audit information	Latest ISO 27001 surveillance audit by The Standards Institution of Israel (SII) on 07-May-2026: Conforms to requirements, zero non-conformities, continued certification recommended.	Available	Section 2.2
Single sign-on (SSO)	SSO via SAML 2.0 is fully supported in the enSights cloud platform.	Fully supported	Section 5
IoT / OT (site device) security	Site telemetry and control traffic is carried over encrypted channels (TLS / site-to-site VPN); device data is technical, non-personal data.	Documented	Section 6
SCIM provisioning	Automated user provisioning and de-provisioning via SCIM is fully supported in the enSights cloud platform.	Fully supported	Section 5

2. Standards compliance and audits

2.1 Certification status

Framework	Status	Detail and source
ISO/IEC 27001:2022	Certified	Information Security Management System (ISMS) certified by The Standards Institution of Israel (SII), Quality & Certification Division. Scope: "Central monitoring and asset management platform for optimizing renewable energy systems." (Audit report p.1; p.8, ISMS 4.3)
SOC 2	In progress – final stages	The SOC 2 examination is in its final stages. The report will be shared with customers under NDA once issued. The ISMS is designed to align with SOC 2 Trust Services Criteria (IS-P-001 Sec. 1.1.5, 21.1).
ISO/IEC 27017 / 27018	Reference framework	Cloud security and cloud PII protection controls are used as reference standards for the Privacy Policy (IS-P-020 Sec. 2). Not separately certified.
Applicable regulation	Compliance commitment	Israeli Privacy Protection Law (1981) and Data Security Regulations (2017), Israeli Computers Law (1995), Israeli Copyright Law (2007) (IS-P-001 Sec. 21.1). US regulatory and contractual requirements are under review as part of the US market expansion (Audit A.5.31, p.8).

2.2 Latest audit – ISO/IEC 27001:2022 surveillance audit

Item	Detail
Certification body	The Standards Institution of Israel (SII) – Quality & Certification Division (SII client no. 500310907)
Audit type / date	Surveillance audit, 07-May-2026, conducted remotely (Audit p.1, p.3)

Item	Detail
Lead auditor	Tal Aviv (SII)
Overall classification	"Conforms to requirements" – the highest of four classifications (Audit p.5)
Auditor recommendation	Continued certification (Audit p.5)
Non-conformities	None – major: 0, minor: 0. No corrective actions outstanding from the previous audit (Audit p.4, p.28)
Opportunities for improvement (OFI)	3 OFIs, none affecting certification: (1) extend interested-parties register to the US market; (2) further formalize ISMS change documentation; (3) extend the risk register to evolving market conditions (Audit p.28)
Management system assessment	Meets requirements; conformity and effectiveness confirmed; audit objectives and criteria achieved (Audit p.4)
Domains sampled	Contexts, Governance, Risk management, Users, Accounts, Access, Assets, Vendors, Incident management, Support utilities, IT operations, Data management, BCM & redundancy, Backup & restore, Monitoring & logs, Network security, Cryptography, Secure code – all "Conforms". Documentation, Employee management and Physical security were not sampled in this cycle, as is standard for a surveillance audit (Audit p.1)

The full audit report can be provided under NDA. The ISO certificate is available on request.

3. Information security policies

enSights maintains a documented ISMS policy set owned by the CISO and approved by the CTO. Each policy is reviewed at least annually (next scheduled review: 15-Jan-2027). The following policies are available to customers under NDA:

ID	Policy	Approved	Covers
IS-P-001	Information Security Policy	10-Mar-2026	Governance and roles, risk assessment, product security and data protection, HR security, endpoint and cloud server security, network security, access control, R&D security, monitoring, compliance and audit
IS-P-003	Secure Development Policy	10-Mar-2026	Secure SDLC, code review, SAST/SCA, secrets management, vulnerability remediation SLAs, environment separation, third-party components and SBOM
IS-P-011	Cloud Based Computing Policy	10-Mar-2026	Shared responsibility model, cloud provider due diligence and contracts, PII processing, IaC and change control, CSPM, network segmentation, resilience
IS-P-014	Business Continuity Policy	22-Apr-2026	BIA, RTO/RPO targets, DR region and recovery phases, immutable backups, BCP/DR testing
IS-P-020	Privacy Policy	10-Mar-2026	PII minimization, use and disclosure, location and storage, encryption, access, retention and disposal, logging

Additional supporting procedures referenced by the auditor (e.g. Access Control Policy, Change Management Policy, Risk Assessment and Treatment Policy, Logging and Monitoring Policy, Incident Response Procedure, Supplier Relationships Policy, Data Security Policy) can be provided on request (Audit pp.9–24).

4. Security controls – requirement-to-source traceability

Each control below states what enSights does, the policy section that mandates it, and the audit evidence where the control was sampled.

Domain	Control	enSights implementation	Policy source	ISO 27001 audit ref.
Governance	ISMS governance	Information Security Steering Committee (CTO, VP R&D, CISO, CFO, COO) approves policies, the annual work plan and classification levels. A CISO (CISO-as-a-service via Up Security) owns the ISMS.	IS-P-001 Sec. 8.2, 8.3	A.5.2, A.5.3, A.5.4 – pp.8–11
Governance	Risk management	Periodic, NIST-based risk assessment covering technical and non-technical risks, including penetration tests and configuration reviews; drives the annual work plan.	IS-P-001 Sec. 12.1–12.3	ISMS 6.1.1–6.1.3, 8.2–8.3 – pp.11–12
Governance	Internal audit & management review	Annual internal ISMS audit and minuted management review; continuous compliance monitoring.	IS-P-001 Sec. 21.2	ISMS 9.2, 9.3 – p.10
Data protection	Tenant isolation	Every customer is provisioned with a unique ID; all application processes are keyed on it to prevent cross-customer data exposure. Customer data is accessible only to that customer's users.	IS-P-001 Sec. 11.8.1–11.8.2	A.8.26 – p.26
Data protection	Encryption at rest	All storage volumes, object storage and databases are encrypted with AES-256; unencrypted production volumes are prohibited.	IS-P-001 Sec. 11.8.4 IS-P-020 Sec. 4.3.2	A.5.14, A.8.24 – pp.22, 25
Data protection	Encryption in transit	All traffic is encrypted over HTTPS/TLS – minimum TLS 1.2, TLS 1.3 by default.	IS-P-001 Sec. 11.3, 17.3 IS-P-020 Sec. 4.3.3 IS-P-011 Sec. 3.3.5	A.8.24 – p.25
Data protection	Personal data minimization	Only limited business PII of platform users is processed (name, business email, business phone for MFA/alerts, IP and system logs). No consumer financial data, card numbers, national IDs or medical data. PII is never sold or used for marketing.	IS-P-020 Sec. 4.1.1–4.1.2 IS-P-011 Sec. 3.3.5	A.5.34 – p.22
Data protection	Data location	Customer production data and backups are hosted in AWS; primary region Ireland (eu-west-1), DR region London (eu-west-2), bounded by the customer MSA.	IS-P-020 Sec. 4.3.1 IS-P-014 Sec. 3.6	Audit pp.6, 23 (A.5.29)
Data protection	Retention & deletion	Customer PII and user configurations purged from active databases within 90 days of contract termination, using cryptographic erasure. Customers may request deletion of their data.	IS-P-020 Sec. 4.4 IS-P-001 Sec. 11.7.1	A.8.10 – p.22
Data protection	Test data	Production customer data is never used in development or test; synthetic or anonymized data only.	IS-P-003 Sec. 5.6	A.8.33 – p.23
Access control	Platform authentication	Platform access requires two-factor authentication and a strong password policy; in addition customers can use SSO (Section 5).	IS-P-001 Sec. 11.4.1	A.8.5 – p.14
Access control	Least privilege	All in-platform resource access is based on IAM roles with minimum permissions. Production access limited to CTO, DevOps and CISO.	IS-P-001 Sec. 11.4.2, 17.2	A.5.15, A.5.18, A.8.2 – p.16
Access control	Access reviews & offboarding	Quarterly access reviews by CISO and CTO. All access revoked within 24 hours of termination. No shared accounts.	IS-P-001 Sec. 17.2	A.5.16, A.5.18 – pp.15–16

Domain	Control	enSights implementation	Policy source	ISO 27001 audit ref.
Access control	Administrative access	MFA mandatory for all administrative access; production console access requires MFA, source-IP restriction and role-based tokens; remote admin access via encrypted channels (VPN / bastion).	IS-P-011 Sec. 5, 6 IS-P-020 Sec. 4.3.4 IS-P-001 Sec. 16.2	A.6.7, A.8.3, A.8.18 – pp.16, 25
Infrastructure	Network security	Production isolated from non-production at network level; deny-by-default rules; no direct public access to backends – all public traffic terminates at a load balancer or WAF; VPC flow logs enabled.	IS-P-011 Sec. 6 IS-P-001 Sec. 15.2, 18.2	A.8.20–A.8.22 – p.25
Infrastructure	Cloud security posture	Shared responsibility model with AWS. Continuous CSPM monitoring; all production infrastructure managed as code (Terraform/Terragrunt) with peer review; manual console changes prohibited except logged break-glass.	IS-P-011 Sec. 1.2, 4, 5 IS-P-001 Sec. 14.2	A.5.23, A.8.9 – pp.18, 20
Infrastructure	Vulnerability management	Continuous scanning of code, dependencies and cloud. Cloud remediation SLAs: Critical 72 h, High 14 days, Medium 30 days. Application code: Critical 7 days, High 14 days. Exceptions require documented CISO risk acceptance.	IS-P-011 Sec. 5 IS-P-003 Sec. 5.5	A.8.8 – p.13
Infrastructure	Penetration testing	Independent third-party penetration test of the production environment at least annually; monthly automated vulnerability scans.	IS-P-001 Sec. 18.2, 21.3	A.8.29 – p.27
Infrastructure	Endpoint security	Managed workstations with EDR, full-disk encryption, auto-lock ≤15 min and automatic security updates.	IS-P-001 Sec. 14.1, 17.4	A.8.1, A.8.7 – pp.12, 20
Secure development	Secure SDLC	Security by design; every change via pull request with independent peer review; automated SAST/SCA and secrets detection on every contribution; OWASP Top 10 (incl. LLM Top 10) standards.	IS-P-003 Sec. 5.1, 5.5 IS-P-001 Sec. 18.1	A.8.25–A.8.28 – pp.26–27
Secure development	Environment separation	Development, staging and production logically separated (separate AWS accounts / VPCs); developers have no write access to production; deployments only via CI/CD.	IS-P-003 Sec. 5.6	A.8.31 – p.21
Secure development	Third-party components	Pinned dependency versions, automatically maintained SBOM, no Critical/High vulnerabilities at merge, removal of EOL components.	IS-P-003 Sec. 6.3–6.6	A.5.21 – p.18
Secure development	Change management	Every production change linked to a ticket; independent review; defined rollback plan for every deployment.	IS-P-001 Sec. 18.3 IS-P-011 Sec. 4	A.8.32 – p.21
Operations	Logging & monitoring	Cloud-native audit logging (e.g. CloudTrail, VPC flow logs) with continuous centralized threat detection for anomalous API calls, privilege escalation and data extraction; security alerts routed to operations in real time.	IS-P-020 Sec. 4.5 IS-P-011 Sec. 6 IS-P-001 Sec. 20.2–20.3	A.8.15, A.8.16 – p.24
Operations	Incident response	NIST-based incident response plan (evaluation, assessment, action, restoration, reporting, lessons learned), external IR team on retainer, evidence and chain-of-custody. Affected customers are notified as part of the incident process.	IS-P-001 Sec. 8.3, 20.4 IS-P-020 Sec. 4.1.3	A.5.24–A.5.28 – pp.19–20

Domain	Control	enSights implementation	Policy source	ISO 27001 audit ref.
Operations	Vendor / sub-processor management	Risk assessment and security contract terms for all cloud providers; annual review of SOC 2 / ISO certifications of critical providers; providers must report breaches within 24 hours.	IS-P-011 Sec. 3.2–3.3 IS-P-003 Sec. 5.2	A.5.19–A.5.23 – p.18
Operations	Personnel security	Confidentiality agreement signed by every employee; annual security awareness training; periodic phishing simulations.	IS-P-001 Sec. 13.1.4, 13.2.3	ISMS 7.3, A.6.3 – p.15
Resilience	Business continuity & DR	Formal BCP with BIA. Targets: RTO 8 hours; RPO 6 hours (general), 1 minute for MongoDB (point-in-time recovery), 6 hours for ClickHouse. Fully scripted DR to a secondary AWS region.	IS-P-014 Sec. 3.3, 3.5, 3.6	A.5.29, A.5.30 – p.23
Resilience	High availability	Production deployed across multiple (3) availability zones; auto-scaling cluster and databases.	IS-P-011 Sec. 8 IS-P-014 Sec. 3.6	A.8.6, A.8.14 – p.23
Resilience	Backups	Automated backups of all production databases; cross-region snapshot copies; immutable backups (S3 Object Lock, compliance mode, 365-day retention).	IS-P-014 Sec. 3.4, 3.7 IS-P-011 Sec. 8	A.7.10, A.8.13 – pp.23–24
Resilience	Testing	BCP/DR tested at least annually with a formal DR test report; backup restoration tested at least annually. Most recent DR test: early May 2026; restore test evidenced to auditor.	IS-P-014 Sec. 3.9 IS-P-011 Sec. 8	A.5.30, A.8.13 – pp.23–24

5. Identity integration – SSO and SCIM

The enSights cloud platform integrates with the customer's corporate identity provider (IdP) so that access to the platform is governed by the customer's own identity lifecycle and authentication policies.

Capability	Status	Detail
Single sign-on (SAML 2.0)	Fully supported	Customer users authenticate to the enSights cloud platform through the customer IdP using SAML 2.0. The customer's IdP policies (MFA, conditional access, session rules) apply at login.
SCIM user provisioning	Fully supported	Users are created, updated and de-provisioned in the enSights platform automatically from the customer IdP via SCIM, so leavers lose platform access as soon as they are disabled in the IdP.
Native authentication (fallback)	Supported	Where SSO is not used, platform login enforces two-factor authentication and a strong password policy (IS-P-001 Sec. 11.4.1).
Role-based access	Supported	Access inside the platform is role-based and least-privilege, restricted to the customer's organizational boundary (IS-P-001 Sec. 11.4.2; IS-P-020 Sec. 4.2).
Customer administration	Supported	Customer administrators can update, correct or remove user accounts and related metadata through the administrative portal (IS-P-020 Sec. 4.2).

Onboarding. SSO and SCIM are configured together with the customer IT team: enSights provides its SAML service-provider metadata and a SCIM endpoint and token; the customer provides IdP metadata and the attribute and role mapping. enSights recommends enabling SCIM together with SSO so that provisioning and de-provisioning are fully automated.

6. IoT / OT and site-device security

The enSights platform collects telemetry from renewable energy assets (solar PV, battery storage, EV charging) and, for energy management (EMS) customers, sends control set-points to site equipment. The table below describes how site devices and this connectivity are secured.

Area	enSights implementation	Source
Integration model	Hardware-agnostic: most asset data is collected from OEM / inverter / datalogger vendor platforms through APIs. Where on-site energy control is required, enSights uses industrial-grade edge gateways (Advantech, Moxa).	Audit pp.6–7
Site-to-cloud connectivity	Site and customer networks connect to the platform over encrypted channels – TLS 1.2+ for API traffic and customer site-to-site VPN tunnels terminating in the enSights AWS VPC. VPN tunnels are included in the scripted DR plan.	IS-P-011 Sec. 3.3.5 IS-P-020 Sec. 4.3.3 IS-P-014 Sec. 3.5, 3.6
Credentials for device / vendor APIs	API keys and integration credentials are stored in a managed secrets vault (AWS Secrets Manager); never hard-coded in source code or images.	IS-P-001 Sec. 18.2 IS-P-003 Sec. 5.7 Audit A.5.21, A.8.33 – pp.18, 23
Telemetry data classification	Device telemetry is technical energy-system data (production, status, performance) and contains no personal data. It is used only for monitoring, analytics and customer-requested workflows.	IS-P-020 Sec. 4.1.2 Audit A.5.31, A.5.34 – pp.8, 22
Data isolation	Telemetry is stored per customer tenant ID and encrypted at rest (AES-256).	IS-P-001 Sec. 11.8.2, 11.8.4
Cloud ingestion endpoints	Public-facing endpoints are protected by AWS WAF and rate limiting; backends are never directly exposed to the internet.	IS-P-001 Sec. 18.2 IS-P-011 Sec. 6
Monitoring	Cloud-native audit logging and continuous threat detection cover the ingestion and control services; security alerts are routed in real time.	IS-P-020 Sec. 4.5 Audit A.8.16 – p.24
Edge gateway hardening & patching	[TO CONFIRM – e.g. default credentials removed, unused ports/services disabled, firmware update process and cadence]	[TO CONFIRM – no dedicated policy section in current ISMS set]
Device authentication	[TO CONFIRM – e.g. per-device certificates / unique credentials, outbound-only connections from site]	[TO CONFIRM]
Control command security	[TO CONFIRM – e.g. authorization and audit log of every set-point sent to site equipment, local override / fail-safe behavior]	[TO CONFIRM]

7. Hosting and architecture overview

Area	Detail and source
Hosting model	100% public cloud (AWS); no servers or network equipment in enSights offices (IS-P-001 Sec. 11.2; Audit p.6)
Regions	Primary: AWS Ireland (eu-west-1). DR: AWS London (eu-west-2) (IS-P-014 Sec. 3.6; Audit p.23)
Compute	Kubernetes (Amazon EKS), microservices deployed via CI/CD and GitOps (IS-P-014 Sec. 3.6; Audit p.20)
Data stores	MongoDB Atlas, ClickHouse Cloud, Amazon RDS, Amazon S3 (IS-P-014 Sec. 3.6)

Area	Detail and source
Secrets	Managed cloud secrets service; secrets never stored in code or images (IS-P-003 Sec. 5.7; IS-P-011 Sec. 4)
Customer connectivity	Data exchange via APIs over TLS; customer site-to-site VPN supported (IS-P-014 Sec. 3.5–3.6; Audit p.6)

8. Requesting documents

Copies of the policies listed in Section 3, the ISO 27001 certificate and the ISO 27001 surveillance audit report are provided to customers under a mutual NDA. The SOC 2 report will be shared under the same terms once issued. Requests and security questionnaires should be sent to the enSights security contact listed on the cover page.

9. Source document index

Reference	Document	Version / date	Owner / approver
IS-P-001	Information Security Policy	1.0 / 27-Feb-2026	CISO / CTO (approved 10-Mar-2026)
IS-P-003	Secure Development Policy	1.0 / 27-Feb-2026	CISO / CTO (approved 10-Mar-2026)
IS-P-011	Cloud Based Computing Policy	1.0 / 06-Apr-2026	CISO / CTO (approved 10-Mar-2026)
IS-P-014	Business Continuity Policy	1.0 / 16-Apr-2026	CISO / CTO (approved 22-Apr-2026)
IS-P-020	Privacy Policy	1.0 / 27-Feb-2026	CISO / CTO (approved 10-Mar-2026)
Audit	ISO/IEC 27001:2022 Surveillance Audit Report, SII (form 190.27001:2022E), 29 pages	07-May-2026	SII – Quality & Certification Division

Citation convention: “Sec.” refers to the numbered section of the policy; “A.x.y” refers to the ISO/IEC 27001:2022 Annex A control as recorded in the audit report; “ISMS x.y” refers to the ISO/IEC 27001:2022 management-system clause; page numbers refer to the audit report.